



TRUST CENTER PAGE SPECIFICATION

Trust Center Specification

Version 1.0

2026-05-22

Prepared for Walker-Miller Energy Services

Entity: Project Baseline, Inc.

Page URL (planned): <https://www.project-baseline.com/trust>

Effective date: 2026-05-22

Version: 1.0

Owner: Todd Walton, Principal

Spec author: PB Pod Lead / Web Designer (Creative & Design Pod)

Build target: Web Developer (Creative & Design Pod, separate session)

1. PURPOSE

The Trust Center is the public-facing security and privacy posture page for Project Baseline, Inc. It exists to:

1. Give prospects and clients a single URL they can review before choosing PB as a vendor or subcontractor
2. Give existing clients (including Walker-Miller) a permanent reference for our security commitments
3. Give regulators, auditors, and security reviewers structured access to our policies, sub-processors, and incident response commitments
4. Be honest. PB is a solo consulting firm, not a SaaS company with a SOC 2 attestation. The Trust Center should communicate the actual security posture with appropriate scope.

2. REFERENCE MODELS

Studied for structure and style, NOT copied:

- **vanta.com/trust:** Sets the "Trust Center" pattern. Tabbed layout with Resources, Compliance, Subprocessors, Documents, Updates. Too SaaS-scaled for PB, but structurally clean.
- **stripe.com/trust:** Long-form single page with sub-sections. Strong design language. Good model for a single-page Trust Center.
- **anthropic.com/trust:** Hybrid. Short overview, expandable sections, downloadable docs. Closest to the right scale for PB.
- **resend.com/legal/security:** Smaller SaaS scale. Direct and honest tone.

PB's Trust Center is single-page, long-scroll, anchor-linked sections, downloadable PDFs, honest scope. Closest in tone to Anthropic and Resend, structurally similar to Stripe.

3. SECTIONS (IN ORDER)

#	SECTION	ANCHOR	PURPOSE
1	Hero	#top	"Security and Privacy at Project Baseline" headline, one-paragraph honest summary, last-updated date, jump links
2	At a glance	#summary	One-screen summary: who we are, what we do, who has access, what we protect, how to contact us about security
3	Compliance and posture	#compliance	Honest statement of certifications (none currently) and the framework we operate against (NIST CSF 2.0 informed)
4	Sub-processors	#subprocessors	Live list of every vendor that processes PB-controlled data, with links to their privacy policies
5	Data handling	#data	Encryption in transit and at rest, retention periods, deletion process
6	Incident response	#incident	72-hour notification SLA, contact email, how to report a security concern
7	Privacy	#privacy	Summary of privacy commitments, link to Privacy Policy v2
8	Policies and documentation	#policies	Downloadable PDF bundle of all 10 PB security policies
9	Roadmap	#roadmap	Honest list of known gaps and target timelines for remediation

#	SECTION	ANCHOR	PURPOSE
10	Contact	#contact	Security email, general contact, PB legal entity details
11	Footer	N/A	Last updated, version, link to changelog

4. SECTION CONTENT

4.1 HERO

Headline: SECURITY AND PRIVACY AT PROJECT BASELINE

Subheadline: How a solo consulting firm protects the information our clients trust us with.

Body paragraph:

Project Baseline, Inc. is a Colorado corporation operated by Todd Walton, providing strategic consulting and AI implementation services to nonprofits, small and mid-market businesses, civic organizations, and individuals. This page documents our security and privacy posture, the policies we operate by, the vendors we share data with, and the commitments we make when something goes wrong. It is updated when our service stack changes or when the underlying policies are revised.

Last updated: 2026-05-22

Jump links: At a glance | Compliance | Sub-processors | Data handling | Incident response | Privacy | Policies | Roadmap | Contact

4.2 AT A GLANCE

A four-card grid (or four-column on desktop, stacked on mobile) summarizing:

CARD	HEADLINE	BODY
Who we are	Project Baseline, Inc.	Colorado profit corporation (EIN 27-0639457), founded 2009. Solo consulting practice headquartered in Broadview, Illinois. Single operator: Todd Walton. No employees with system access.
What we do	Strategic consulting and AI implementation	Nonprofit consulting, strategy consulting, AI implementation, AI training, subcontractor engagements, and free and paid AI-assisted tools at ai.project-baseline.com and alkermillertad.project-baseline.com .
What we protect	Client and prospect data	Engagement deliverables, intake responses, uploaded documents, payment metadata (no card data; Stripe handles cards), AI tool submissions, communications. See Data handling.
How to reach us	todd@project-baseline.com	Security questions, vulnerability reports, privacy requests, incident notifications, and general inquiries all route to todd@project-baseline.com . Acknowledged within 7 days.

4.3 COMPLIANCE AND POSTURE

Headline: COMPLIANCE AND POSTURE

Honest framing paragraph:

Project Baseline is a solo consulting firm. We are not currently SOC 2 Type II attested, ISO 27001 certified, HIPAA-attested, or PCI-DSS attested. We do not represent ourselves as such. What we are is a single-operator practice that has implemented and documented controls aligned with the NIST Cybersecurity Framework 2.0 (NIST CSF 2.0), scaled appropriately for our size and scope.

Subsection: NIST CSF 2.0 alignment

We operate against the six NIST CSF 2.0 functions:

- **Govern (GV):** Information Security Policy, Vendor and Sub-Processor Management Policy, Risk Register, annual review cadence
- **Identify (ID):** PB Security Inventory documenting every system, sub-processor, data flow, and identified gap (last updated 2026-05-22)
- **Protect (PR):** Access Control Policy (MFA on all SaaS accounts, SSH key-only on infrastructure), Cryptography Policy (TLS 1.2+, bcrypt cost factor 12, AES-256 at rest where applicable), Acceptable Use Policy, Data Retention Policy, Backup Policy
- **Detect (DE):** Structured logging on infrastructure, sub-processor security alerts (GitHub, Cloudflare, Stripe, Google Workspace, DigitalOcean), application-level abuse-control telemetry (rate limits, daily spend caps, honeypot fields)
- **Respond (RS):** Incident Response Plan with 72-hour breach notification SLA to affected clients and regulators where applicable
- **Recover (RC):** Backup Policy (encrypted, off-site, 90-day rolling retention plus annual archives), documented restoration testing cadence

Subsection: Certifications and attestations

- SOC 2 Type II: Not currently attested. Not on roadmap for 2026 (size and scope do not justify cost).
- ISO 27001: Not currently certified.
- HIPAA: Not applicable. We do not process Protected Health Information.
- PCI-DSS: Not directly applicable. Payment card data is processed by Stripe (PCI-DSS Level 1 attested); PB never receives or stores cardholder data.
- GDPR / UK GDPR / CCPA: We honor data subject rights under these laws and other comprehensive US state privacy laws. See our Privacy Policy.

If our service stack grows to a scale where a formal attestation makes sense for the business, we will pursue it and update this page.

4.4 SUB-PROCESSORS

Headline: SUB-PROCESSORS

Intro paragraph:

The vendors below process PB-controlled data on our behalf. Each is selected with documented risk assessment, contractual protections through their Data Processing Addenda or equivalent commitments, and ongoing monitoring. We notify clients with active engagements at least 30 days before adding a new sub-processor that will process their data.

Table: Render as a striped table on desktop, accordion on mobile.

#	SUB-PROCESSOR	SERVICE	DATA TYPE	LOCATION	PRIVACY POLICY LINK
1	Google LLC (Google Workspace)	Email, document storage, scheduling	Communications, documents, deliverables	United States	policies.google.com/privacy
2	Cloudflare, Inc.	DNS, TLS, WAF, DDoS	Web traffic	United States (edge worldwide)	cloudflare.com/privacypolicy
3	GitHub, Inc. (Microsoft)	Site hosting, source code	Public marketing content; source code	United States	docs.github.com/en/site-policy/privacy-policies/github-general-privacy-statement
4	Stripe, Inc.	Payment processing	Payment metadata; PB never sees card numbers	United States	stripe.com/privacy
5	FormSubmit.co	Form relay for one inquiry form	Name, email, business name, message	United States	formsubmit.co/privacy
6	Anthropic, PBC	AI generation	Business context for AI tools	United States	anthropic.com/legal/privacy
7	OpenAI, L.L.C.	Occasional AI use	Limited business context	United States	openai.com/policies/privacy-policy
8	Google LLC (Gemini API)	Occasional AI use	Limited business context	United States	policies.google.com/privacy
9	Perplexity AI, Inc.	Research lookups	Search queries (no client PII)	United States	perplexity.ai/hub/legal/privacy-policy
10	Resend, Inc.	Email delivery	Recipient email, subject, body, attachments	United States	resend.com/legal/privacy-policy

#	SUB-PROCESSOR	SERVICE	DATA TYPE	LOCATION	PRIVACY POLICY LINK
11	Fireflies.ai (Fred AI, Inc.)	Meeting transcription	Meeting audio and transcripts	United States	fireflies.ai/privacy-policy
12	DigitalOcean, LLC	VPS infrastructure hosting	All self-hosted application data	United States	digitalocean.com/legal/privacy-policy
13	Supabase, Inc.	Database services	Limited operational data	United States	supabase.com/privacy
14	Mailchimp (Rocket Science Group LLC)	Email marketing (not currently active)	Contact info for opt-in recipients only	United States	mailchimp.com/legal/privacy

Note about FormSubmit.co: This is the highest-risk active sub-processor in our registry. It operates as a free service without a Data Processing Addendum option. Volume is low (a few inquiry-form submissions per month) and data sensitivity is low (name, email, business name, free-text message). We are migrating to a same-origin or contracted alternative within 90 days of this page's effective date.

Sub-processor change subscription: To be notified of sub-processor changes, email todd@project-baseline.com with the subject line "Sub-processor notifications."

4.5 DATA HANDLING

Headline: HOW WE HANDLE DATA

Three columns (or stacked on mobile):

Encryption in transit

- TLS 1.2 or higher on all customer-facing endpoints
- HTTPS enforced (HTTP requests 301 redirect to HTTPS)
- Cloudflare-managed TLS termination on most domains, with origin TLS verified
- Let's Encrypt certificates with automatic renewal

Encryption at rest

- Google Workspace: AES-256 (provider-managed)
- DigitalOcean infrastructure: AES-256 (provider-managed)

- GitHub repositories: provider-managed encryption
- Operator endpoint: BitLocker XTS-AES 256 with TPM-backed key storage
- Stripe payment data: PCI-DSS Level 1 (we never receive card data)
- Application-layer encryption on operator-controlled SQLite databases: not currently in place; covered by infrastructure-layer encryption and filesystem permissions, on the remediation roadmap

Retention and deletion

We retain only what we need, only for as long as we need it. Full retention schedule is in our Data Retention Policy (downloadable below). Highlights:

- AI tool abuse-control records: 90 days
- AI tool generated PDFs (server cache): 7 days
- Client uploaded documents: 90 days post-engagement, or 30 days post-account deletion
- Client engagement deliverables: duration of engagement plus 7 years (legal and tax record retention)
- System logs: 30 days
- Backups: 90 days rolling plus annual archives

4.6 INCIDENT RESPONSE

Headline: INCIDENT RESPONSE

Body:

If we confirm a security incident that affects your information, we notify you within 72 hours of confirmed exposure. Notification includes what happened, what information was involved, what we are doing about it, what you can do, and how to contact us with questions.

Severity-based response targets:

SEVERITY	DEFINITION	RESPONSE TIME
Sev-1 Critical	Active compromise of client data with confirmed exposure	Immediate
Sev-2 High	Active or imminent threat without confirmed exposure	Within 4 hours
Sev-3 Medium	Suspicious activity without immediate threat	Within 24 hours
Sev-4 Low	Operational anomaly with security implications	Within 72 hours

Notification channels: Direct email from todd@project-baseline.com, follow-up call within 24 hours of email for Sev-1 incidents.

To report a security concern: Email todd@project-baseline.com with the subject line "Security." We acknowledge security reports within 24 hours. For responsible disclosure of a vulnerability you have identified in a PB tool, the same address applies; we do not currently operate a public bug bounty.

Our complete Incident Response Plan (severity definitions, response phases, contact list, communication templates) is downloadable below.

4.7 PRIVACY

Headline: PRIVACY

Body:

We do not sell or share your personal information for advertising. We do not use cross-site tracking or third-party advertising cookies. We do not use your information to train artificial intelligence models, and we contractually prohibit our AI sub-processors from doing so.

You have the right to access, correct, delete, and export your personal information. California residents have additional rights under the CCPA. Residents of the EEA, UK, and Switzerland have additional rights under GDPR. We respond to privacy requests within 7 days of receipt and complete most requests within 30 days.

Full Privacy Policy: <https://www.project-baseline.com/privacy>

To submit a privacy request: Email todd@project-baseline.com with the subject line "California Privacy Request," "GDPR Request," or "Privacy Request" as applicable.

4.8 POLICIES AND DOCUMENTATION

Headline: POLICIES AND DOCUMENTATION

Intro:

The complete PB security policy bundle is available below. These are the documents we operate by; they are also available to clients and prospects on request.

Downloadable PDF list (10 policies):

1. Information Security Policy (master policy)
2. Acceptable Use Policy
3. Access Control Policy
4. Cryptography Policy
5. Data Retention Policy
6. Vendor and Sub-Processor Management Policy
7. Incident Response Plan
8. Backup Policy
9. Confidentiality and NDA Template
10. Security Awareness Training Record (annual self-attestation log)

Each item is a button: Document title, file size, last updated date, "Download PDF" action.

Note about access: Some clients and prospects may need versions of these policies with additional detail (controls evidence, audit logs, environment-specific configuration). Request the extended versions by email; we will evaluate the request and respond within 7 days.

4.9 ROADMAP

Headline: WHAT WE ARE WORKING ON

Intro:

We document known gaps and work on them in priority order. Updates are posted as items are completed.

Table:

GAP	STATUS	TARGET
Cloudflare proxy for walkermillertad subdomain	In progress	Q2 2026
FormSubmit.co migration to same-origin or contracted form alternative	In planning	Within 90 days of this page's effective date (by August 2026)
Application-layer encryption on operator-controlled SQLite databases	Evaluating options	Q3 2026
Off-VPS encrypted backup automation (rclone + Backblaze B2)	In progress	Q2 2026
Quarterly backup restoration test cadence	First test scheduled	Q3 2026
Annual tabletop incident response exercise	Scheduled	Q2 2026

Note: This roadmap is intentionally honest. If a security reviewer or client identifies an additional concern, we add it here.

4.10 CONTACT

Headline: CONTACT

Three columns (stacked on mobile):

Security and privacy questions

Email: todd@project-baseline.com

Acknowledged within: 24 hours for security; 7 days for privacy

Use subjects: "Security," "California Privacy Request," "GDPR Request," or "Sub-processor notifications"

General contact

Email: todd@project-baseline.com

Phone: (855) 616-6333

Website: www.project-baseline.com

Legal entity

Name: Project Baseline, Inc.

State of incorporation: Colorado

EIN: 27-0639457

Principal place of business: Broadview, Illinois

Sole officer: Todd Walton, Principal

4.11 FOOTER

Last updated: 2026-05-22 | Version 1.0 | Changelog (when applicable)

Links to: [Privacy Policy](#) | [Terms of Service](#) | [Home](#)

5. DESIGN AND BUILD REQUIREMENTS

5.1 BRAND CONSISTENCY

- Fonts: Bebas Neue for H1, H2, H3 headings; Montserrat for body text. Match [project-baseline.com](#).
- Colors: Red accent #E31B23, off-black headings #1A1A1A, body text #333333, page background #ffffff, section dividers #f8f8f8 with #eee borders. Match [project-baseline.com](#).
- Logo: PB wordmark in nav, matches existing site
- Iconography: Use Heroicons or Feather icons (free, MIT-licensed) for section anchors; lock icon for security, shield for compliance, database for data, exclamation for incident, info for privacy, document for policies, road for roadmap, envelope for contact

5.2 LAYOUT

- Max-width container: 1100px for content, full-width hero section
- Sticky sub-nav appears on scroll past the hero, with anchor jump links highlighted as user scrolls
- Tables: striped rows, sortable not required (small datasets)
- Mobile breakpoint: 768px. Tables become accordions; columns stack.
- Print stylesheet: clean printable version with policy links rendered as URLs

5.3 ACCESSIBILITY

- WCAG 2.1 AA compliance
- All interactive elements keyboard accessible
- All images have alt text
- Color contrast minimum 4.5:1 for body text
- Heading hierarchy preserved (no skipped levels)
- Skip-to-content link at the top

5.4 PERFORMANCE

- Static HTML, no client-side framework
- Inline critical CSS (above-the-fold styles), defer rest
- Lazy-load PDF preview images (if any)
- Lighthouse Performance score target: 95+
- Lighthouse Accessibility score target: 100
- No tracking scripts, no analytics, no ad networks

5.5 SEO

- Page title: "Trust Center | Project Baseline"
- Meta description: "Security, privacy, sub-processors, incident response, and policies for Project Baseline, Inc., a Colorado consulting corporation."
- canonical URL: <https://www.project-baseline.com/trust>
- Open Graph image: PB Trust Center social card (Web Designer to design)
- Structured data: Organization schema with security/privacy fields

5.6 PDFS IN POLICIES SECTION

- All 10 policy PDFs must be generated from the markdown source in `02-security-program/` using the standard PDF generator
- File size shown for each (rough: 50-200 KB each)
- Last updated date shown for each
- "Download PDF" button opens in new tab
- Optionally: render a "Preview" inline collapsible with the first paragraph of each policy

5.7 VERSIONING AND CHANGELOG

- Page footer shows current version and last updated date
- Changelog page (separate URL: </trust/changelog>) lists material changes by date
- When a sub-processor is added, removed, or changed, log it in the changelog

- When a policy version increments, log it
 - When a new attestation is achieved, log it
-

6. HONEST SCOPE NOTES (READ BEFORE BUILDING)

This is a solo consulting firm's Trust Center, not a SaaS company's Trust Center.

The page must:

- Communicate the actual scope (one operator, no employees with system access, no separate IT team)
- Avoid corporate "we" framing that implies a team larger than reality
- Use plain English, not security marketing jargon ("we encrypt your data" not "we leverage enterprise-grade encryption infrastructure")
- Acknowledge gaps explicitly (FormSubmit.co risk, no SOC 2, no separate DPO role)
- Use "the operator" or "Todd Walton" where the singular accountability is important
- Use "Project Baseline" or "we" where the entity perspective is appropriate

The page must NOT:

- Imply we have a security operations center
- Imply we have employees other than Todd
- Imply we have certifications we do not have
- Use vague phrases like "industry-leading," "best-in-class," "robust"
- Promise things we cannot deliver (zero breaches, perfect security, 100% uptime)

If in doubt about scope or framing, send to QA-02 (Completeness Auditor) before publish.

7. BUILD DELIVERY CHECKLIST

When the Web Developer builds this page, they must deliver:

- `[] trust-center.html` saved in the workspace (NOT deployed to production until Todd approves)

- ☐ All 10 policy PDFs generated and placed in a `policies/` subfolder beside the HTML
- ☐ All sub-processor privacy policy URLs verified (no broken links)
- ☐ Mobile responsiveness tested at 375px, 768px, 1024px, 1440px viewports
- ☐ Lighthouse audit run, scores documented in the build delivery report
- ☐ Print stylesheet tested with a PDF print test
- ☐ Accessibility audit run (axe-core or Wave)
- ☐ Routed through CD-00 (Creative Director) for visual QA
- ☐ Routed through QA-02 (Completeness Auditor) for final scope and accuracy check
- ☐ Build delivery report saved to `02-security-program/trust-center-build-report.md`

Only after all of the above pass does the file get deployed to `project-baseline.com/trust`.

Document control

- Spec version: 1.0
- Spec effective date: 2026-05-22
- Spec owner: PB Pod Lead
- Build owner: Web Developer (Creative & Design Pod)
- QA owners: Creative Director (CD-00), Completeness Auditor (QA-02)
- Deployment owner: Todd Walton

Signature: Todd Walton, Principal, Project Baseline, Inc.

Date: 2026-05-22

END OF DOCUMENT

Project Baseline, Inc. | Colorado | EIN 27-0639457 | todd@project-baseline.com | project-baseline.com

This document is the confidential property of Project Baseline, Inc. and the intended recipient. Unauthorized distribution is prohibited.